

Study Report: Cybersecurity Analyst - Career Path & Core Skills

Written by Gagan Pasupuleti

Family:	Cybersecurity Analyst
Level:	Beginner to Advanced
Tracks:	Beginner, Intermediate, Advanced
Chapters:	18
Source:	Official docs, free libraries, and industry-standard references (see sources and books)

Official sources and free libraries

- <https://owasp.org/Top10/>
- <https://www.nist.gov/cyberframework>
- <https://attack.mitre.org/>
- <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- <https://learn.microsoft.com/security/>
- <https://www.cisa.gov/topics/cybersecurity-best-practices>

Summary

Cybersecurity analyst path covering OWASP Top 10 2021, NIST Cybersecurity Framework, MITRE ATT&CK tactics and techniques, SIEM detection engineering, incident response playbooks, vulnerability management, and zero trust architecture. Emphasizes hands-on blue-team skills with Python automation for log analysis and threat hunting.

Skill stack by level

Recommended books

1. The Web Application Hacker's Handbook - Dafydd Stuttard & Marcus Pinto

Level: Advanced | OWASP-style web attacks, testing methodology, and defenses.

2. OWASP Top Ten - OWASP Foundation

Level: Beginner | Free guide to the ten most critical web application risks (2021).

3. Blue Team Handbook - Don Murdoch

Level: Intermediate | SOC operations, log analysis, and incident triage playbooks.

4. NIST Cybersecurity Framework - NIST

Level: Intermediate | Identify, Protect, Detect, Respond, Recover - free official guide.

5. Practical Malware Analysis - Michael Sikorski & Andrew Honig

Level: Advanced | Reverse engineering and malware triage for security analysts.

End-to-end projects

Project 1: Home Lab Security Hardening

Beginner | 2 weeks - Harden a Linux VM: firewall, SSH keys, fail2ban, updates, and document baseline checklist.

- Baseline: Baseline audit
- Harden: Hardened VM
- Verify: Before/after comparison
- Document: Hardening runbook PDF

Project 2: Web App Security Assessment

Intermediate | 3-4 weeks - OWASP Top 10 assessment of a demo web app: ZAP scan, manual testing, remediation report.

- Recon: App inventory
- Scan: ZAP report HTML
- Manual: Manual test log
- Report: Security assessment PDF

Project 3: SOC Alert Triage Playbook

Advanced | 4-5 weeks - Build SIEM detection rules, triage 10 alert scenarios, write IR playbook, conduct tabletop exercise.

- Detect: Rule definitions
- Triage: Triage playbook PDF
- IR: IR playbook
- Exercise: Exercise report

Chapters

Track: Beginner

Chapter 1: Security Analyst Role and Defense in Depth [Beginner]

Chapter focus: Security Analyst Role and Defense in Depth** *(Level: Beginner)

Security analysts protect confidentiality, integrity, and availability. Defense in depth layers controls: policies, network segmentation, identity, endpoint, application, and monitoring. Blue team focuses on detect-and-respond; understand red team findings without becoming adversarial. Document everything-incidents become legal evidence.

Code Reference:

```
layers = ['Policy', 'Perimeter', 'Network', 'Host', 'App', 'Data', 'Monitoring']
```

What it shows: Layer model explains where controls belong in architecture reviews.

Topic guide

What it actually is

Cybersecurity analysts detect threats and reduce organizational risk.

When to use it

Continuous monitoring of enterprise IT and cloud estates.

Where to use it

SOCs, MSSPs, internal security teams, and compliance-heavy orgs.

Real use example

CodeQuest SOC analyst spots unusual API traffic pattern during nightly log review.

Chapter 2: OWASP Top 10 2021 Overview [Beginner]

Chapter focus: OWASP Top 10 2021 Overview** *(Level: Beginner)

OWASP Top 10 lists critical web risks: Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable Components, Auth Failures, Integrity Failures, Logging Failures, and SSRF. Developers and analysts share this vocabulary for prioritization.

Code Reference:

```
owasp_2021 = ['A01 Broken Access Control', 'A02 Crypto Failures', 'A03 Injection',  
             'A04 Insecure Design', 'A05 Misconfiguration']
```

What it shows: Enumerating categories structures appsec assessment checklists.

Topic guide

What it actually is

OWASP Top 10 is the industry standard web application risk list.

When to use it

Web app pen tests, secure SDLC training, and bug bounty triage.

Where to use it

SaaS products, education portals, and e-commerce platforms.

Real use example

IDOR in quiz API lets student A view student B grades-A01 broken access control.

Chapter 3: CIA Triad and Authentication Basics [Beginner]

Chapter focus: CIA Triad and Authentication Basics** *(Level: Beginner)

Confidentiality (encryption, access control), Integrity (hashing, signing), Availability (redundancy, DDoS mitigation). Authentication proves identity; authorization grants permissions. MFA blocks most credential stuffing. Password policies alone are insufficient.

Code Reference:

```
import hashlib
hashlib.sha256(b'password123').hexdigest() # never store plaintext
```

What it shows: Hashing demos why databases must not store raw passwords.

Topic guide

What it actually is

CIA triad frames every security control decision.

When to use it

Designing systems handling student PII and payment data.

Where to use it

Identity systems, databases, and API gateways.

Real use example

MFA rollout stops 99% of spray attempts against teacher admin portal.

Chapter 4: Network Security Fundamentals [Beginner]

Chapter focus: Network Security Fundamentals** *(Level: Beginner)

Understand TCP/IP, ports, firewalls, VPNs, TLS, and DNS security. North-south traffic crosses perimeter; east-west traffic between servers needs microsegmentation. PCAP analysis with Wireshark reveals malware beaconing and data exfil.

Code Reference:

```
# tshark filter: tls.handshake.extensions_server_name contains 'codequest'
# Suricata rule alerts on suspicious outbound 443
```

What it shows: Packet filters isolate TLS SNI and IDS alert patterns.

Topic guide

What it actually is

Network security controls traffic paths and visibility.

When to use it

Investigating C2 traffic and firewall change requests.

Where to use it

Corporate LAN, cloud VPCs, and hybrid connectivity.

Real use example

Firewall log shows workstation contacting rare IP on 4444-quarantine triggered.

Chapter 5: Vulnerability Management Lifecycle [Beginner]

Chapter focus: Vulnerability Management Lifecycle** *(Level: Beginner)

Discover assets, scan for CVEs, prioritize by exploitability and asset criticality, patch or mitigate, verify closure. CVSS provides base scores; contextual risk adds internet exposure and data sensitivity. SLAs: critical internet-facing in 72 hours.

Code Reference:

```
finding = {'cve': 'CVE-2024-1234', 'cvss': 9.8, 'asset': 'web-prod-01', 'sla_days': 3}
```

What it shows: Structured finding dicts feed ticketing and SLA dashboards.

Topic guide

What it actually is

Vulnerability management reduces known exploitable weaknesses.

When to use it

Monthly patch cycles and audit preparation.

Where to use it

Servers, containers, SaaS connectors, and third-party libs.

Real use example

Critical OpenSSL flaw on CodeQuest edge node patched within 48-hour SLA.

Chapter 6: Security Policies and Compliance Basics [Beginner]

Chapter focus: Security Policies and Compliance Basics** *(Level: Beginner)

Policies define acceptable use, data classification, incident reporting, and access reviews. Frameworks: ISO 27001, SOC 2, GDPR, FERPA for education data. Analysts translate controls into technical implementations auditors can test.

Code Reference:

```
classifications = {'Public': 0, 'Internal': 1, 'Confidential': 2, 'Restricted': 3}
```

What it shows: Data classification drives encryption and DLP requirements.

Topic guide

What it actually is

Policies and compliance align security with legal obligations.

When to use it

Onboarding vendors, student data platforms, and annual audits.

Where to use it

Schools, healthcare, fintech, and government contractors.

Real use example

FERPA review requires student quiz data encrypted at rest and role-scoped access.

Track: Intermediate

Chapter 7: NIST Cybersecurity Framework [Intermediate]

Chapter focus: NIST Cybersecurity Framework *(Level: Intermediate)**

NIST CSF functions: Identify (asset management), Protect (access control), Detect (anomalies), Respond (incidents), Recover (backups). Create Current Profile vs Target Profile gap reports for leadership funding asks.

Code Reference:

```
functions = ['Identify', 'Protect', 'Detect', 'Respond', 'Recover']
```

What it shows: CSF functions organize control maturity assessments.

Topic guide

What it actually is

NIST CSF provides a common risk management vocabulary.

When to use it

Enterprise security program design and board reporting.

Where to use it

US critical infrastructure and widely adopted globally.

Real use example

Gap analysis shows Detect immature-funds SIEM and SOC headcount.

Chapter 8: MITRE ATT&CK for Detection [Intermediate]

Chapter focus: MITRE ATT&CK for Detection *(Level: Intermediate)**

ATT&CK catalogs adversary tactics (Initial Access, Execution, Persistence?) and techniques (T1059 PowerShell). Map detections and purple team tests to technique IDs. Navigator layers visualize coverage gaps.

Code Reference:

```
technique = {'id': 'T1110.001', 'name': 'Password Guessing', 'tactic': 'Credential Access'}
```

What it shows: Technique metadata enriches SIEM alert descriptions.

Topic guide

What it actually is

MITRE ATT&CK standardizes threat behavior knowledge.

When to use it

Detection engineering, threat intel, and purple teaming.

Where to use it

SOCs building coverage dashboards for leadership.

Real use example

New rule detects T1110.001 brute force-closes Navigator gap for Credential Access.

Chapter 9: SIEM Architecture and Log Sources [Intermediate]

Chapter focus: SIEM Architecture and Log Sources *(Level: Intermediate)**

SIEM aggregates logs: AD, EDR, firewall, cloud trail, app logs. Normalization, retention, and correlation rules produce alerts. Tune noisy rules-alert fatigue causes missed true positives. Store raw logs immutably for forensics.

Code Reference:

```
# Sentinel table: SecurityEvent | where EventID == 4625 | summarize count() by Account
```

What it shows: Failed logon aggregation detects brute-force patterns.

Topic guide**What it actually is**

SIEM is the central nervous system for security monitoring.

When to use it

24/7 SOC operations and compliance log retention.

Where to use it

Microsoft Sentinel, Splunk Enterprise Security, Elastic.

Real use example

Spike in 4625 events across VPN-correlation opens incident within minutes.

Chapter 10: Incident Response Phases [Intermediate]

Chapter focus: Incident Response Phases *(Level: Intermediate)**

NIST IR: Preparation, Detection & Analysis, Containment, Eradication, Recovery, Post-Incident. Preserve chain of custody for disk images. Communicate via predefined templates-avoid leaking indicators in public channels.

Code Reference:

```
phases = ['Prepare', 'Detect', 'Contain', 'Eradicate', 'Recover', 'Lessons']
```

What it shows: Phase checklist ensures no step skipped during chaos.

Topic guide**What it actually is**

Incident response minimizes damage from confirmed breaches.

When to use it

Active malware, account compromise, and data breach events.

Where to use it

CERT teams, MSSP escalations, and internal IR retainers.

Real use example

Ransomware contained by VLAN isolation while backups verified offline.

Chapter 11: Endpoint Detection and Response [Intermediate]

Chapter focus: Endpoint Detection and Response *(Level: Intermediate)**

EDR agents record process trees, file hashes, registry changes, and network connections. Hunt for living-off-the-land binaries (lolbas) like certutil and powershell -enc. Isolate hosts from console before wiping reimages.

Code Reference:

```
# EDR query: parent_process == 'winword.exe' AND child_process == 'powershell.exe'
```

What it shows: Parent-child process anomalies indicate macro malware.

Topic guide**What it actually is**

EDR provides deep endpoint telemetry beyond antivirus signatures.

When to use it

Malware outbreaks and insider threat investigations.

Where to use it

CrowdStrike, Microsoft Defender for Endpoint, SentinelOne.

Real use example

Word spawns encoded PowerShell-EDR auto-isolates laptop before lateral scan.

Chapter 12: Web App Security Testing [Intermediate]

Chapter focus: Web App Security Testing *(Level: Intermediate)**

Manual and automated testing for SQLi, XSS, CSRF, SSRF, and auth bypass. Burp Suite intercepts HTTP traffic; ZAP automates baseline scans. Always test in scoped environments with written authorization-unauthorized testing is illegal.

Code Reference:

```
# sqlmap authorized test only on lab.codequest.local  
# python -m pip install sqlmap
```

What it shows: Tooling reminders stress authorized scope boundaries.

Topic guide

What it actually is

Appsec testing finds flaws before attackers exploit production.

When to use it

Release gates for customer-facing web applications.

Where to use it

Bug bounty, internal QA security, and dev team training.

Real use example

Burp reveals admin API missing auth-fixed before production release.

Chapter 13: Phishing Analysis and Email Security [Intermediate]

Chapter focus: Phishing Analysis and Email Security** *(Level: Intermediate)

Analyze headers (SPF, DKIM, DMARC), extract URLs and attachments in sandbox. User reporting buttons feed SOC queues. Run simulated phishing campaigns to measure click rates and train high-risk departments.

Code Reference:

```
import re
urls = re.findall(r'https?://\S+', email_body)
```

What it shows: Regex extraction feeds URL reputation checks.

Topic guide

What it actually is

Email security blocks primary initial access vector.

When to use it

Daily SOC triage and security awareness programs.

Where to use it

Microsoft 365 Defender, Proofpoint, Mimecast.

Real use example

Fake payroll email links to credential harvest-blocked at gateway after header fail.

Track: Advanced

Chapter 14: Zero Trust Architecture [Advanced]

Chapter focus: Zero Trust Architecture** *(Level: Advanced)

Zero trust assumes breach: verify explicitly, least privilege, assume breach. Identity becomes

perimeter via Conditional Access, device compliance, and microsegmentation. Replace flat network VPN with app-level access policies.

Code Reference:

```
policy = {'user': 'teacher', 'device': 'compliant', 'app': 'gradebook', 'action': 'allow'}
```

What it shows: Policy tuples express zero trust decision logic.

Topic guide**What it actually is**

Zero trust modernizes perimeter-centric security models.

When to use it

Cloud migration, remote work, and high-value data protection.

Where to use it

Azure AD Conditional Access, Zscaler, BeyondCorp patterns.

Real use example

Non-compliant phone blocked from admin portal even on corporate Wi-Fi.

Chapter 15: Threat Hunting with Python [Advanced]**Chapter focus: Threat Hunting with Python** *(Level: Advanced)**

Proactive hunts query SIEM and endpoint data for hypotheses: uncommon parent-child pairs, rare process command lines, beaconing intervals. Python pandas ingests exported logs for statistical anomaly detection beyond static rules.

Code Reference:

```
import pandas as pd
ev = pd.read_json('edr_events.jsonl', lines=True)
rare = ev.groupby('process').size().sort_values().head(20)
```

What it shows: pandas surfaces rare processes worthy of manual investigation.

Topic guide**What it actually is**

Threat hunting finds undetected adversary activity.

When to use it

Mature SOCs after baseline detections are tuned.

Where to use it

Fortune 500 SOCs and critical infrastructure CSIRTs.

Real use example

Hunt finds periodic 90-second HTTPS beacons missed by threshold alerts.

Chapter 16: Cloud Security and IAM [Advanced]

Chapter focus: Cloud Security and IAM** *(Level: Advanced)

Misconfigured S3 buckets, overly broad IAM roles, and public security groups cause breaches. Enforce least privilege, MFA on root, CloudTrail logging, and CSPM scanning. Understand shared responsibility model per provider.

Code Reference:

```
# aws iam simulate-principal-policy (conceptual)
# Azure PIM for just-in-time admin
```

What it shows: IAM simulation tests effective permissions before deployment.

Topic guide

What it actually is

Cloud security secures ephemeral infrastructure and identities.

When to use it

AWS/Azure/GCP migrations and multi-cloud estates.

Where to use it

SaaS backends and data lakes storing learner analytics.

Real use example

CSPM flags public S3 bucket with grade exports-emergency lockdown.

Chapter 17: Digital Forensics Essentials [Advanced]

Chapter focus: Digital Forensics Essentials** *(Level: Advanced)

Acquire disk images write-blocked; hash with SHA-256; analyze with Autopsy or Volatility for memory forensics. Timeline analysis correlates events. Legal hold preserves evidence for potential litigation-chain of custody forms mandatory.

Code Reference:

```
sha256 = 'a3f2...' # verify image integrity before analysis
```

What it shows: Hash verification proves evidence not tampered.

Topic guide

What it actually is

Forensics supports IR root cause and legal proceedings.

When to use it

Confirmed breaches requiring evidence preservation.

Where to use it

Law enforcement liaison and internal fraud cases.

Real use example

Memory dump reveals attacker RDP session artifacts for timeline.

Chapter 18: Security Automation and SOAR [Advanced]

Chapter focus: Security Automation and SOAR *(Level: Advanced)**

SOAR playbooks automate enrichment (WHOIS, VirusTotal), ticket creation, and containment actions with human approval gates. Python scripts glue APIs when commercial SOAR unavailable. Measure MTTR improvement after automation.

Code Reference:

```
def enrich_ip(ip):  
    return {'ip': ip, 'vt_score': query_vt(ip), 'action': 'block_if_malicious'}
```

What it shows: Enrichment functions feed playbook decision branches.

Topic guide**What it actually is**

Security automation scales analyst capacity and speeds response.

When to use it

High-volume alert environments and repetitive tier-1 tasks.

Where to use it

Splunk SOAR, Palo Alto XSOAR, custom Lambda responders.

Real use example

Phishing playbook auto-quarantines attachment in 90 seconds vs 25-minute manual average.